SIMATS ENGINEERING

Saveetha Institute of Medical And Technical Sciences

ASSESSMENT TOOL 1

Report Analysis

Name	**B Akshaya**
Register Number	**192424336**
Date	**22.10.2026**

COURSE CODE: ITA1420

COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

CO2: *Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.*

Assessment Tool Weightage: 30% | Duration: 90 min | Total Marks: 50

Code of Conduct:

I B Akshaya (192424336) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Akshaya

Question 1: Nmap Scan of 192.168.1.10 (20 Marks)

A security analyst scanned 192.168.1.10 with Nmap. The report lists open ports HTTP (80), SSH (22) and MySQL (3306), along with the operating system and service versions. This answer analyzes the report, explains the risks, shows how an attacker could exploit each service, and recommends countermeasures.

1.0 Scan Methodology and Sample Output

The scan was performed in an authorized lab/assessment environment. A typical command that produces this kind of report is shown below. The flags enable a SYN scan, service/version detection, OS detection and targeted port selection.

```
nmap -sS -sV -O -p 22,80,3306 192.168.1.10
```

```
PORT     STATE SERVICE VERSION
22/tcp  open  ssh     OpenSSH [version] (protocol 2.0)
80/tcp  open  http    Apache httpd [version]
3306/tcp open  mysql   MySQL [version]
OS details: Linux [kernel range]
```

Illustrative output format (version strings depend on the actual report):

Nmap reports each port as **open** (a service is listening), **closed** (reachable but nothing listening) or **filtered** (a firewall hides the state). Here all three ports are **open**, meaning they are directly reachable from the scanning host. Every open port is a possible entry point, so each one must have a clear business justification.

1.1 Interpretation of the Report

Port	Service	Protocol	Purpose
22	SSH	TCP	Encrypted remote administration
80	HTTP	TCP	Unencrypted web server
3306	MySQL	TCP	Database server

The OS and version details come from Nmap service detection (-sV) and OS detection (-O). This is **active footprinting**: it gives an attacker the attack surface of the host and lets them match each exact version to known CVEs. A web server, an admin service and a database on one host indicate a typical LAMP-style web stack, where the web application is the front door to the data stored in MySQL.

1.2 Security Risks of the Identified Services

A. HTTP (Port 80)

- Traffic is unencrypted, so credentials, cookies and form data can be sniffed (man-in-the-middle).
- Web applications may suffer SQL injection, XSS, file inclusion, directory traversal and broken access control (OWASP Top 10).
- Outdated web server versions carry publicly known CVEs.
- Version banners, default pages and directory listing leak information.

B. SSH (Port 22)

- A constant target for brute-force and credential-stuffing attacks.
- Weak or default passwords and permitted root login greatly increase risk.
- Old versions or weak algorithms (SSHv1, weak ciphers) contain known flaws.
- A compromised SSH account gives a full command shell on the server.

C. MySQL (Port 3306)

- A database should never be reachable from untrusted networks.
- Weak or blank root passwords, anonymous users and default settings are common.
- Unpatched versions may allow authentication bypass or privilege escalation.
- Successful access leads to theft, modification or deletion of data (loss of confidentiality, integrity and availability).

1.3 How an Attacker Could Exploit These Services

Stage	Attacker activity
Reconnaissance	Uses Nmap results (ports, versions, OS) to select targets.
Vulnerability mapping	Matches service versions to NVD / Exploit-DB entries.
HTTP attack	Finds an injectable or vulnerable page; steals data or uploads a web shell.
SSH attack	Password guessing or reuse of leaked credentials to obtain a shell.
MySQL attack	Remote login with weak credentials; dumps databases.
Post-exploitation	Privilege escalation, lateral movement, persistence, data exfiltration.

Example attack chain: web vulnerability, then database credentials found in a config file, then MySQL access, then a reused password for SSH, ending in full server compromise.

1.4 Recommended Security Measures

Area	Countermeasures
Network	Firewall with default-deny rules; block port 3306 externally and bind MySQL to 127.0.0.1 or the app server only; restrict SSH to trusted IPs or a VPN; deploy IDS/IPS (Snort, Suricata); segment the network (DMZ for web, internal zone for database).
HTTP	Enforce HTTPS/TLS with redirect and HSTS; patch server and application; hide banners (ServerTokens Prod) and disable directory listing; deploy a Web Application Firewall; use input validation and parameterized queries.
SSH	Disable password login and use key-based authentication; PermitRootLogin no; enable MFA; install Fail2Ban; allow SSHv2 with strong ciphers only.
MySQL	Run mysql_secure_installation; remove anonymous users and test databases; strong passwords and least-privilege accounts; TLS for connections; encrypt sensitive data; patch regularly; enable audit logging.

General	Regular vulnerability scans and penetration tests; patch management; centralized logging and SIEM monitoring; backups; OS hardening using CIS benchmarks.

1.5 Risk Rating of the Findings

Finding	Likelihood	Impact	Severity
MySQL (3306) exposed to the network	High	High (data loss/theft)	**Critical**
HTTP (80) without encryption, possibly outdated web stack	High	High (web compromise, credential theft)	**High**
SSH (22) open to all sources	Medium	High (full shell access)	**High**
OS and version disclosure via banners	High	Low to Medium (aids targeting)	**Medium**

1.6 CIA Triad and MITRE ATT&CK Mapping

Attacker action	MITRE ATT&CK technique	CIA impact
Port and service scanning	T1595 Active Scanning	Confidentiality (information leak)
Exploiting web application flaws	T1190 Exploit Public-Facing Application	Confidentiality, Integrity
Guessing SSH or MySQL passwords	T1110 Brute Force	Confidentiality
Logging in with stolen credentials	T1078 Valid Accounts	Confidentiality, Integrity, Availability
Dumping or deleting database content	T1005 Data from Local System / T1485 Data Destruction	Confidentiality, Availability

1.7 Sample Hardening Configuration

The following snippets show how the recommendations translate into real configuration (adjust paths and IPs to the environment).

```
# /etc/ssh/sshd_config
PermitRootLogin no
PasswordAuthentication no
PubkeyAuthentication yes
MaxAuthTries 3
Protocol 2

# Firewall (ufw)
ufw default deny incoming
ufw allow from 192.168.1.0/24 to any port 22 proto tcp
ufw allow 443/tcp
ufw deny 3306/tcp

# /etc/mysql/my.cnf
bind-address = 127.0.0.1
local-infile = 0

# Apache
ServerTokens Prod
ServerSignature Off
Options -Indexes
```

1.8 Remediation Roadmap

Priority	Action	Timeline
Immediate	Block external access to 3306; disable SSH password login and root login; change default and weak passwords.	0 to 24 hours
Short term	Patch OS, web server, SSH and MySQL; enable HTTPS and HSTS; deploy Fail2Ban and a WAF.	1 to 2 weeks
Medium term	Network segmentation, centralized logging with SIEM alerts, MFA for administrative access.	1 to 3 months
Ongoing	Monthly vulnerability scans, periodic penetration tests, patch management and security reviews.	Continuous

Conclusion: Even three common services can give an attacker a complete path to compromise when they are exposed, outdated or poorly configured. Defense-in-depth (firewall, patching, strong authentication, encryption and monitoring) greatly reduces the risk.

Question 2: GoPhish Phishing Campaign - ABC Technologies Pvt. Ltd. (20 Marks)

2.0 Campaign Setup in GoPhish

GoPhish is an open-source phishing simulation framework used by organizations to measure how employees respond to realistic attacks. The campaign for ABC Technologies Pvt. Ltd. was built from the following components:

GoPhish component	Purpose in this campaign
Sending Profile	SMTP configuration used to deliver the simulated emails.
Email Template	Realistic message (for example a password-expiry or HR notice) with a tracking link and an attachment.
Landing Page	Cloned login page that records whether credentials were submitted (the values are not misused).
Users and Groups	List of employees targeted, organized by department.
Campaign and Dashboard	Launches the exercise and tracks Sent, Opened, Clicked, Submitted Data and Reported events.

2.1 Interpretation of the Report

Metric	Result	Meaning
Clicked phishing link	40%	4 in 10 employees trusted a malicious link.
Entered credentials	20%	Half of those who clicked also gave away login details.
Downloaded attachment	Several users	Malware could have executed on company devices.

The GoPhish funnel (Sent, Opened, Clicked, Submitted Data) shows that the **human layer is the weakest link**. A 20% credential-submission rate is very high: in a real attack, a single stolen account can lead to a full breach.

2.2 Security Weaknesses Demonstrated

- **Lack of security awareness:** employees cannot recognize phishing indicators such as spoofed senders, urgency and mismatched URLs.
- **Trust and authority bias:** people obey emails that appear to come from HR, IT or management.
- **Poor verification habits:** links are not hovered over and domains are not checked.
- **Weak password hygiene:** credentials typed into a fake page may be reused on other systems.
- **No reporting culture:** suspicious emails are not reported to the security team.
- **Unsafe attachment handling:** files are opened without verifying the sender.
- **Likely technical gaps:** the mail gateway did not block the message and MFA was not limiting the damage.

2.3 Recommendations

A. User Awareness Programs

- Mandatory security awareness training at onboarding and at least quarterly.

- Regular simulated phishing campaigns with immediate feedback (teachable moment).
- Teach red flags: urgency, spelling errors, unknown senders, suspicious links, unexpected attachments.
- One-click "Report Phishing" button in the email client.
- Role-based training for high-risk groups (HR, finance, executives).
- Recognition for employees who report; a no-blame culture.

B. Email Security Controls

- Configure **SPF, DKIM and DMARC** to stop domain spoofing.
- Secure email gateway with spam, phishing and malware filtering.
- Attachment sandboxing and URL rewriting/scanning.
- Block risky file types (.exe, .js, macro-enabled documents) and tag external emails with a warning banner.
- Enforce **Multi-Factor Authentication** so a stolen password alone is not enough.

C. Organizational Policies

- Acceptable-use and email security policy.
- Password policy with a password manager and no password reuse.
- Incident response plan for reporting suspected phishing, including immediate password reset.
- Least-privilege access and second-channel verification for sensitive requests (payments, credentials).
- Endpoint protection (EDR/antivirus), application restrictions and regular patching.
- Track click rate and report rate, with periodic management review.

2.4 Campaign Results at a Glance

Employee response to the phishing simulation (% of targeted employees)



Half of the employees who clicked the link went on to enter credentials, which shows that most users did not stop to verify the page after clicking. The attachment downloads add a second

infection path (malware) on top of credential theft.

2.5 Psychological Triggers Used by Attackers

Trigger	How the phishing email uses it	Defensive habit
Authority	Appears to come from HR, IT or a senior manager.	Verify unusual requests through a separate channel.
Urgency	"Your account will be locked in 2 hours."	Pause; urgency is a warning sign.
Fear	Threatens suspension or penalties.	Contact the helpdesk directly.
Curiosity / reward	Salary revision, bonus or policy attachment.	Do not open unexpected attachments.
Familiarity	Copies company logos and writing style.	Check sender domain and URL carefully.

2.6 Potential Business Impact

- **Account takeover:** stolen credentials give access to email, VPN and internal applications.
- **Business email compromise:** attackers impersonate staff to redirect payments.
- **Malware and ransomware:** a downloaded attachment can install a backdoor or encrypt files.
- **Data breach:** customer and company data may be stolen, leading to legal and regulatory penalties.

- **Reputation and financial loss:** downtime, recovery cost and loss of customer trust.

2.7 Suggested Training Calendar and Success Metrics

Activity	Frequency	Target group
Induction security awareness session	At joining	All new employees
Short refresher modules / videos	Quarterly	All employees
Simulated phishing campaign (GoPhish)	Every 1 to 2 months	All employees, rotating templates
Advanced social engineering training	Half-yearly	HR, finance, executives, IT helpdesk

Metric	Current (from report)	Target after training
Link click rate	40%	Below 10%
Credential submission rate	20%	Below 3%
Suspicious emails reported	Low / not tracked	Above 70%
Time to report an incident	Not measured	Within 15 minutes

2.8 Response Steps if an Employee Falls for a Phishing Email

- Report the email immediately using the Report Phishing button or the security team.
- Reset the compromised password and revoke active sessions and tokens.
- Isolate the device if an attachment was opened and run an endpoint scan.
- Review mail and authentication logs for suspicious sign-ins.
- Block the sender domain and URL, and remove the email from all mailboxes.
- Document the incident and use it as a lesson in the next awareness session.

Conclusion: Technology alone cannot stop social engineering. Continuous awareness training, strong email controls, MFA and enforced policies together reduce click and credential-submission rates.

Question 3: DNS Zone Transfer (AXFR) using Dig (10 Marks)

3.0 Background: DNS Records and Zone Transfers

DNS translates domain names into IP addresses. A **zone file** contains every record of a domain. Primary and secondary name servers synchronize the zone using **AXFR** (full zone transfer) over TCP port 53. Because the zone file is effectively a directory of the organization's infrastructure, only authorized secondary servers should be able to request it.

Record	Meaning	Information exposed
A / AAAA	Hostname to IPv4 / IPv6 address	Server locations and IP ranges
CNAME	Alias to another name	Cloud and third-party services in use
MX	Mail server of the domain	Email infrastructure
NS	Authoritative name servers	DNS topology
TXT	Free text (SPF, verification tokens)	Mail policy and SaaS providers
PTR / SRV	Reverse lookup / service location	Internal service discovery

3.1 Interpretation of the Report

```
dig axfr example.com @ns1.example.com
```

The assessment typically uses:

A successful **AXFR** means the DNS server handed the entire zone file to an unauthorized requester. Zone transfers must be allowed only between trusted primary and secondary servers. The report exposed internal hostnames, mail servers (MX) and other records (A, CNAME, TXT, NS).

3.2 Security Implications of the Exposed Information

- **Complete network map:** the attacker learns the infrastructure without any scanning.
- **Internal names exposed:** hosts such as dev, test, vpn, admin and db reveal high-value targets.
- **Mail servers revealed:** they become targets for phishing, spoofing and email attacks.
- **Forgotten assets:** staging and legacy servers are often poorly secured.

- **IP disclosure:** gives ready targets for port scanning and exploitation.
- **TXT records** may expose SPF settings and third-party services.

3.3 How Attackers Could Exploit the Findings

- Run targeted Nmap scans and vulnerability discovery against the listed hosts.
- Attack weak development or test servers first.
- Craft convincing phishing and social engineering using real hostnames and mail servers.
- Perform subdomain takeover where records point to unused services.
- Plan DoS or DNS poisoning attacks against the identified name servers.

3.4 Best Practices to Secure the DNS Infrastructure

Control	Description
Restrict AXFR	Allow transfers to authorized secondaries only, e.g. allow-transfer { trusted-IP; }; in BIND.
TSIG	Authenticate and secure zone transfers with transaction signatures.
Control	**Description**
Split-horizon DNS	Keep internal records invisible to external queries.
Record hygiene	Remove stale and unnecessary records; hide version information.
DNSSEC and filtering	Deploy DNSSEC, rate limiting and firewall rules for port 53.
Recursion and patching	Disable recursion for external users; patch DNS software.
Monitoring and audit	Review logs; audit regularly with dig, nslookup and dnsrecon.

3.5 Assessment Steps and Illustrative Output

```
dig NS example.com +short
dig axfr example.com @ns1.example.com
```

The assessor first finds the authoritative name servers and then tests whether each one allows a transfer:

Illustrative (fictional) output of a vulnerable server:

```
example.com.        IN SOA  ns1.example.com. admin.example.com. ...
```

```
www.example.com.   IN A      192.0.2.10
mail.example.com.  IN A      192.0.2.25
vpn.example.com.   IN A      192.0.2.30
dev.example.com.   IN A      10.0.5.21
db01.example.com.  IN A      10.0.5.40
example.com.       IN MX     10 mail.example.com.
```

A secure server instead returns Transfer failed. or REFUSED. The presence of private addresses (10.x.x.x) in a publicly obtained zone is especially serious, because it reveals the internal addressing scheme.

3.6 Risk Assessment and MITRE ATT&CK Mapping

Exposed item	Why it matters	Severity
Internal hostnames and private IPs	Reveals internal network layout; helps lateral movement planning.	**High**
Mail server records	Enables targeted phishing and spoofing.	**Medium**
Dev / test / admin hosts	Often weakly protected and lightly monitored.	**High**
TXT and CNAME records	Discloses third-party services; subdomain takeover possible.	**Medium**

This activity maps to MITRE ATT&CK **T1590.002 (Gather Victim Network Information: DNS)** and **T1596.001 (Search Open Technical Databases: DNS/Passive DNS)** in the reconnaissance phase. The zone transfer alone does not compromise a system, but it removes the attacker's need to scan and guess, and it accelerates every later stage.

```
zone "example.com" {
  type master;
  file "/etc/bind/db.example.com";
  allow-transfer { 192.0.2.2; };  # secondary only
  also-notify { 192.0.2.2; };
};
```

3.7 Sample Secure Configuration (BIND)

```
options {
  allow-recursion { 192.168.1.0/24; };
  version "not disclosed";
};
```

After applying the change, the assessment should be repeated: dig axfr example.com @ns1.example.commust now return a refused or failed transfer from every name server.

3.8 Verification Checklist

- Zone transfer refused from unauthorized hosts on all authoritative servers.
- Transfers between primary and secondary protected with TSIG keys.
- Internal records removed from the public zone (split-horizon DNS in place).
- Stale records and unused subdomains deleted; no dangling CNAMEs.
- DNSSEC enabled and port 53 restricted by firewall rules.
- DNS logs monitored for repeated AXFR or unusual query patterns.

Conclusion: An open zone transfer hands attackers a free blueprint of the network. Restricting AXFR, using TSIG and split DNS, and auditing regularly will protect the DNS infrastructure.

Overall Summary of the Three Reports

Report	Key finding	Main risk	Top countermeasure
Nmap scan (Q1)	SSH, HTTP and MySQL open	Remote compromise and database theft	Firewall default-deny, patching, close 3306 externally
GoPhish (Q2)	40% clicked, 20% gave credentials	Account takeover and malware infection	Awareness training, SPF/DKIM/DMARC, MFA
Dig AXFR (Q3)	Zone transfer allowed	Complete infrastructure disclosure	Restrict AXFR, TSIG, split-horizon DNS

Together these reports show how footprinting works across the technical layer (ports and services), the human layer (social engineering) and the infrastructure layer (DNS). An ethical hacker uses all three views to identify weaknesses early, report them with clear evidence, and recommend layered .

References

- OWASP Foundation, *Top 10 Web Application Security Risks* and *Web Security Testing Guide*.
- NIST SP 800-115, *Technical Guide to Information Security Testing and Assessment*.
- CIS Benchmarks for server hardening; Nmap Reference Guide (nmap.org); GoPhish documentation; ISC BIND 9 Administrator Reference Manual.